

УЧЁТНЫЕ ЗАПИСИ ПОЛЬЗОВАТЕЛЕЙ

Жизненный цикл учетной записи и основные угрозы

Учетная запись — ключ к цифровой ЛИЧНОСТИ

Центр атаки: **Учетная запись — главная цель злоумышленника**. Это точка входа к персональным данным, финансам, привилегиям.

Последствия компрометации:

- Утечка конфиденциальных данных.
- Финансовые потери (кража средств, мошеннические операции).
- Репутационный ущерб (рассылка спама от имени пользователя).
- Горизонтальное/вертикальное перемещение в системе (атака на других пользователей или получение прав администратора).

Статистика: **Большинство утечек данных начинается с компрометации учетных записей (слабые пароли, фишинг, уязвимости).**

Этапы существования учетной записи и риски на каждом

Регистрация: Валидация данных, проверка уникальности, защита от ботов.

Аутентификация: Доказательство того, что пользователь — это он. **Риски:** брутфорс, кража сессий, фишинг.

Авторизация: Определение прав доступа. **Риски:** вертикальное/горизонтальное повышение привелегий.

Работа с учетной записью: Смена пароля, email, настройки 2FA. **Риски:** недостаточная проверка владельца.

Восстановление доступа: Самый уязвимый этап. **Риски:** перехват кодов, социальная инженерия.

Деактивация/Удаление: **Риски:** остаточные данные, возможность восстановления «удаленного» аккаунта.

Как не пустить злоумышленника с порога?

Валидация входных данных: Защита от инъекций, XSS в полях имени, email.

Борьба с ботами и спам-регистрацией:

- CAPTCHA (современные, невидимые варианты).
- Лимиты на регистрацию с IP/за промежуток времени.

Верификация email/номера телефона (обязательный шаг).

Политика паролей: Требования к сложности НО без излишних ограничений.

КТО ВЫ И ЧТО ВАМ МОЖНО?

Аутентификация (Кто вы?):

- **Многофакторная аутентификация:** Обязательна для критичных операций. Типы: TOTP (Google Authenticator), SMS (менее безопасно), Push-уведомления, аппаратные ключи (FIDO2/WebAuthn).
- **Защита сессий:** Надежные, случайные токены, HttpOnly, Secure флаги у куки.
- **Контроль активных сессий:** Возможность просмотра и отзыва сессий.

КТО ВЫ И ЧТО ВАМ МОЖНО?

Авторизация (Что вам можно?):

- **Принцип минимальных привилегий:** Пользователь получает ровно столько прав, сколько нужно.
- **Проверка на стороне сервера:** Никогда не доверять клиенту. Каждый запрос должен проверять права пользователя к запрашиваемому ресурсу.

Самые тонкие места

Безопасное управление:

- **Смена пароля:** Требовать старый пароль. Новый пароль не должен совпадать с предыдущими.
- **Смена email:** Подтверждение по старому и новому email (двойная верификация).
- **Просмотр истории действий/логинов.**

Самые тонкие места

Восстановление доступа:

- 1) Уязвимый канал: Секретные вопросы (легко угадать), SMS-коды.
- 2) Лучшие практики:
 - Использовать заранее проверенный второй фактор (приложение-аутентификатор, резервные коды).
 - Отправлять одноразовую ссылку на подтвержденный email с ограниченным временем жизни.
 - Задержка и уведомление: После восстановления — задержка перед критичными действиями, оповещение на все старые каналы связи.

Как крадут аккаунты?

Брутфорс и использование утекших паролей.

Фишинг и социальная инженерия: Обман пользователя.

Перехват сессий: XSS, кража куки, MiTM-атаки.

Уязвимости в логике приложения:

- Сброс пароля на чужой email (недостаточная проверка).
- Предсказуемые токены восстановления.
- Неправильная авторизация (IDOR).

Атаки на инфраструктуру: Взлом почты пользователя, SIM-swapping.

Стратегия защиты

- 1) Для пользователя: Менеджеры паролей, уникальные пароли для каждого сервиса, включение 2FA.
- 2) Для разработчика:
 - Хэширование паролей: Только стойкие алгоритмы с солью.
 - Защита от перебора: Лимиты попыток входа, капча, увеличение задержки.
 - Логирование безопасности: Все важные события (логин, смена пароля, вход с нового устройства) с метаданными (IP, User-Agent).
 - Регулярный аудит: Проверка старых сессий, отзыв токенов при смене пароля.
 - Уведомления пользователя: О подозрительной активности (новый IP-адрес, устройство).

Ключевые принципы безопасности учетных записей

- 1) Безопасность учетной записи — это сквозной процесс, охватывающий весь ее жизненный цикл.
- 2) Самый слабый элемент — человек. Обучение пользователей и продуманный UX безопасности критически важны.
- 3) Многофакторная аутентификация — это обязательно для любого серьезного сервиса.
- 4) Защита от автоматизации (капча, лимиты) и качественное логирование — основа для обнаружения атак.
- 5) Никогда не изобретайте велосипед для криптографии (хэширование) и аутентификации. Используйте проверенные стандарты и библиотеки.